

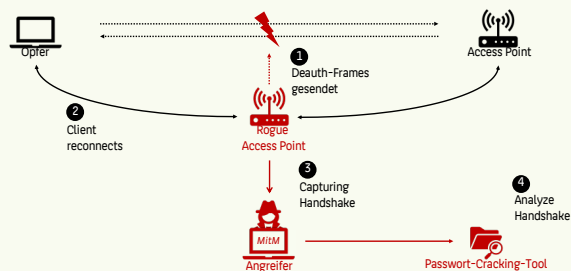


Man-in-the-Middle-Angriff im WLAN: Demonstration, Risiken und Wirtschaftlichkeit von Gegenmaßnahmen

Einleitung

WLAN-Infrastrukturen sind ein attraktives Angriffsziel, da veraltete Sicherheitsstandards wie WPA2 mit geringem Aufwand kompromittiert werden können. Dieses Projekt demonstriert in einer zwei Man-in-the-Middle-Szenarien: den externen Angriff auf WPA2-Netzwerke mittels Deauthentication sowie den internen Angriff durch DNS-Spoofing zur Credential-Exfiltration. Die anschließende ROSI-Analyse bewertet praxisnahe Gegenmaßnahmen wie WPA3-Migration, HTTP-Blockierung und Passworrichtlinien hinsichtlich ihrer Wirtschaftlichkeit, um Entscheidungsträger:innen evidenzbasierte Handlungsempfehlungen bereitzustellen.

Wi-Fi Deauthentication Angriff (extern)



Ablauf

Ein Deauthentication-Angriff "kicked" Clients aus dem WPA2-Netzwerk, indem der Angreifer gefälschte Management-Frames sendet (①). Beim automatischen Wiederverbindungsversuch (②) fängt der Angreifer mit dem WiFi Pineapple MK7 den 4-Wege-Handshake ab und speichert diesen im PCAP- und Hashcat-22000-Format (③). Anschließend wird das WLAN-Passwort offline mittels Brute-force-Angriff (Hashcat) geknackt (④) - bei schwachen Passwörtern innerhalb von Minuten erfolgreich.

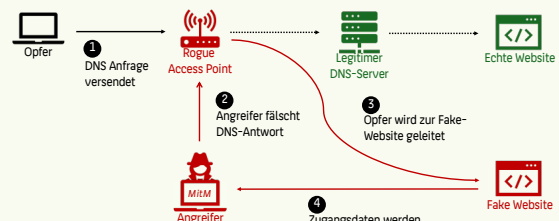
Folgen

- Missbrauch der Internetverbindung (illegale Downloads, Angriffe auf Dritte)
- Zugriff auf interne Systeme und sensible Daten
- Ausgangspunkt für weitere Angriffe (ARP-Spoofing, DNS-Spoofing)

Risikobasis (Expected Annual Loss – EAL)

200.000 € Schaden x 3 % Wahrscheinlichkeit = **6.000 € / Jahr**

DNS-Spoofing Angriff (intern)



Ablauf

Nach erfolgreichem Netzwerkzugang positioniert sich der Angreifer als Man-in-the-Middle und manipuliert DNS-Anfragen der Clients. Der Opfer-Client sendet eine DNS-Anfrage (①), die vom WiFi Pineapple als Rogue Access Point abgefangen wird (②). Dieser fungiert als zentraler DNS-Server und löst legitime Domains wie "bank.de" auf die IP-Adresse des angreiferkontrollierten Webserver auf. Clients werden auf eine täuschend echte Phishing-Seite umgeleitet (③), die Zugangsdaten abfängt und protokolliert (④).

Folgen

- Diebstahl von Zugangsdaten (Bank, Unternehmensportale, E-Mail-Systeme)
- Finanzieller Schaden durch Kontomissbrauch
- Angriffe auf interne Systeme mit Credentials

Risikobasis (Expected Annual Loss – EAL)

150.000 € Schaden x 1 % Wahrscheinlichkeit = **1.500 € / Jahr**

Gegenmaßnahmen

WPA 3 Einführung

- Kryptografischer Schutz von Management-Frames
- Verhindert Deauth-Angriffe & Mitschneiden des Handshakes
- Deutlich höhere WLAN-Grundsicherheit

Kosten: 1.500 € (10 APs à 100 € Mehrkosten + 500 € Admin)

Risikoreduktion: 90 %

ROSI: (6.000 € x 90 % - 1.500 €) / 1.500 € = **260 %**

Starke WLAN Passwörter

- Erhöhen Aufwand für Brute-Force- & Wörterbuchangriffe
- Reduzieren Risiko kompromittierter Zugänge
- Keine zusätzliche Hardware erforderlich

Kosten: 30 € (30 Min. Admin-Aufwand)

Risikoreduktion: 60 %

ROSI: (6.000 € x 60 % - 30 €) / 30 € = **11.900 %**

Port 80 Blockierung

- Verhindert unverschlüsselten HTTP-Traffic
- Erzwingt HTTPS-Only-Kommunikation
- Minimale Kosten, maximale Wirkung

Kosten: 30 € (30 Min. Admin-Aufwand)

Risikoreduktion: 80 %

ROSI: (1.500 € x 80 % - 30 €) / 30 € = **39 %**

Handlungsempfehlung

Auf Basis der Risikoanalyse wird dringend empfohlen, sofort strengere Passworrichtlinien einzuführen. Mit einem ROSI von 11.900% und minimalen Kosten von nur 30 € ist dies die wirtschaftlich effektivste Sofortmaßnahme. Parallel dazu sollte Port-80-Blockierung implementiert werden, um unverschlüsselten HTTP-Traffic zu verhindern. Strategisch ist zudem die Migration auf WPA3 einzuplanen (ROSI: 260%). Nur dieser Standardwechsel eliminiert die protokollbedingten Schwachstellen von WPA2 vollständig. Die Kombination aller drei Maßnahmen reduziert das Gesamtrisiko um ca. 80% bei überschaubaren Gesamtkosten von 1.560 €.

htw Hochschule für Technik und Wirtschaft Berlin
University of Applied Sciences

Dimitrij Tjumenzew,
Eric Grätsch,
Milan Roeting,
Viet Anh Hönemann

